Guidance on privacy and the use of commercially available AI products

oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/guidance-on-privacy-and-the-use-of-commercially-available-ai-products

October 21, 2024



Privacy

Privacy guidance for organisations and government agencies

- Organisations
- Government agencies
- Guidance on privacy and developing and training generative AI models
- Guidance on privacy and the use of commercially available AI products
- Health service providers
- Handling personal information
- Privacy impact assessments
- COVID-19
- More guidance

Listen

- **On this page**

- Top five takeaways

- Quick reference guide
- Overview
- Artificial intelligence and privacy
- Interaction with Voluntary AI Safety Standard
- What should organisations consider when selecting an AI product?
- What are the key privacy risks when using AI?
- What transparency and governance measures are needed?
- What ongoing assurance processes are needed?
- Checklists

Published:
Updated:





Top five takeaways

1. **Privacy obligations will apply to any personal information input into an AI system, as well as the output data generated by AI (where it contains personal information).** When looking to adopt a commercially available product, organisations should conduct due diligence to ensure the product is suitable to its intended uses. This should include considering whether the product has been tested for such uses, how human oversight can be embedded into processes, the potential privacy and security risks, as well as who will have access to personal information input or generated by the entity when using the product.
2. **Businesses should update their privacy policies and notifications with clear and transparent information about their use of AI,** including ensuring that any public facing AI tools (such as chatbots) are clearly identified as such to external users such as customers. They should establish policies and procedures for the use of AI systems to facilitate transparency and ensure good privacy governance.

3. **If AI systems are used to generate or infer personal information, including images, this is a collection of personal information and must comply with APP 3.** Entities must ensure that the generation of personal information by AI is reasonably necessary for their functions or activities and is only done by lawful and fair means. Inferred, incorrect or artificially generated information produced by AI models (such as hallucinations and deepfakes), where it is about an identified or reasonably identifiable individual, constitutes personal information and must be handled in accordance with the APPs.
4. **If personal information is being input into an AI system, APP 6 requires entities to only use or disclose the information for the primary purpose for which it was collected,** unless they have consent or can establish the secondary use would be reasonably expected by the individual, and is related (or directly related, for sensitive information) to the primary purpose. A secondary use may be within an individual's reasonable expectations if it was expressly outlined in a notice at the time of collection and in your business's privacy policy.
5. **As a matter of best practice, the OAIC recommends that organisations do not enter personal information, and particularly sensitive information, into publicly available generative AI tools**, due to the significant and complex privacy risks involved.



Quick reference guide

- The Privacy Act applies to all uses of AI involving personal information.
- This guidance is intended to assist organisations to comply with their privacy obligations when using commercially available AI products, and to assist with selection of an appropriate product. However, it also addresses the use of AI products which are freely available, such as publicly accessible AI chatbots.
- Although this guidance applies to all types of AI systems involving personal information, it will be particularly useful in relation to the use of generative AI and general-purpose AI tools, as well as other uses of AI with a high risk of adverse impacts. It does not cover all privacy issues and obligations in relation to the use of AI, and should be considered together with the *Privacy Act 1988* - external site (Privacy Act) and the *Australian Privacy Principles guidelines*.
- A number of uses of AI are low-risk. However, the use of personal information in AI systems is a source of significant community concern and depending on the use case, may be a high privacy risk activity. The OAIC, like the Australian community, therefore expects organisations seeking to use AI to take a cautious approach to these activities and give due regard to privacy in a way that is commensurate with the potential risks.

Selecting an AI product

- Organisations should consider whether the use of personal information in relation to an AI system is necessary and the best solution in the circumstances – AI products should not be used simply because they are available.
- When looking to adopt a commercially available product, businesses should conduct due diligence to ensure the product is suitable to its intended uses. This should include considering whether the product has been tested for such uses, how human oversight can be embedded into processes, the potential privacy and security risks, as well as who will have access to personal information input or generated by the entity when using the product.
- Due diligence for AI products should not amount to a 'set and forget' approach. Regular reviews of the performance of the AI product itself, training of staff and monitoring should be conducted throughout the entire AI product lifecycle to ensure a product remains fit for purpose and that its use is appropriate and complies with privacy obligations.

Privacy by design

Organisations considering the use of AI products should take a 'privacy by design' approach, which includes conducting a Privacy Impact Assessment.

Transparency

Organisations should also update their privacy policies and notifications with clear and transparent information about their use of AI, including ensuring that any public facing AI tools (such as chatbots) are clearly identified as such to users. They should establish policies and procedures for the use of AI systems to facilitate transparency and ensure good privacy governance.

Privacy risks when using AI

- Organisations should be aware of the different ways they might be handling personal information when using AI systems. Privacy obligations will apply to any personal information input into an AI system, as well as the output data generated by AI (where it contains personal information).
- Personal information includes inferred, incorrect or artificially generated information produced by AI models (such as hallucinations and deepfakes), where it is about an identified or reasonably identifiable individual.
- If personal information is being input into an AI system, APP 6 requires entities to only use or disclose the information for the primary purpose for which it was collected, unless they have consent or can establish the secondary use would be reasonably expected by the individual, and is related (or directly related, for sensitive information) to the primary purpose.

- A secondary use may be within an individual's reasonable expectations if it was expressly outlined in a notice at the time of collection and in your organisation's privacy policy. Whether APP 5 notices or privacy policies were updated, or other information was given at a point in time after the collection, may also be relevant to this assessment. It is possible for an individual's reasonable expectations in relation to secondary uses to change over time.
- Given the significant privacy risks presented by AI systems, it may be difficult to establish reasonable expectations for an intended use of personal information for a secondary, AI-related purpose. Where an organisation cannot clearly establish that such a secondary use was within reasonable expectations, to avoid regulatory risk they should seek consent for that use and/or offer individuals a meaningful and informed ability to opt-out.
- As a matter of best practice, the OAIC recommends that organisations do not enter personal information, and particularly sensitive information, into publicly available AI chatbots and other publicly available generative AI tools, due to the significant and complex privacy risks involved.
- If AI systems are used to generate or infer personal information, this is a collection of personal information and must comply with APP 3. Entities must ensure that the generation of personal information by AI is reasonably necessary for their functions or activities and is only done by lawful and fair means.
- Organisations must take particular care with sensitive information, which generally requires consent to be handled. Many photographs or recordings of individuals (including artificially generated ones) contain sensitive information and therefore may not be able to be generated by, or used as input data for, AI systems without the individual's consent. Consent cannot be implied merely because an individual was notified of a proposed collection of personal information.
- The use of AI in relation to decisions that may have a legal or similarly significant effect on an individual's rights is likely a high privacy risk activity, and particular care should be taken in these circumstances, including considering accuracy and the appropriateness of the product for the intended purpose.

Accuracy

- AI systems are known to produce inaccurate or false results. This risk is especially high with generative AI, which is probabilistic in nature and does not 'understand' the data it handles or generates.
- Under APP 10, organisations have an obligation to take reasonable steps to ensure the personal information collected, used and disclosed is accurate. Organisations must consider this obligation carefully and take reasonable steps to ensure accuracy, commensurate with the likely increased level of risk in an AI context, including the appropriate use of disclaimers which clearly communicate any limitations in the accuracy of the AI system, or other tools such as watermarks.

Downloads

Updated: 21 October 2024



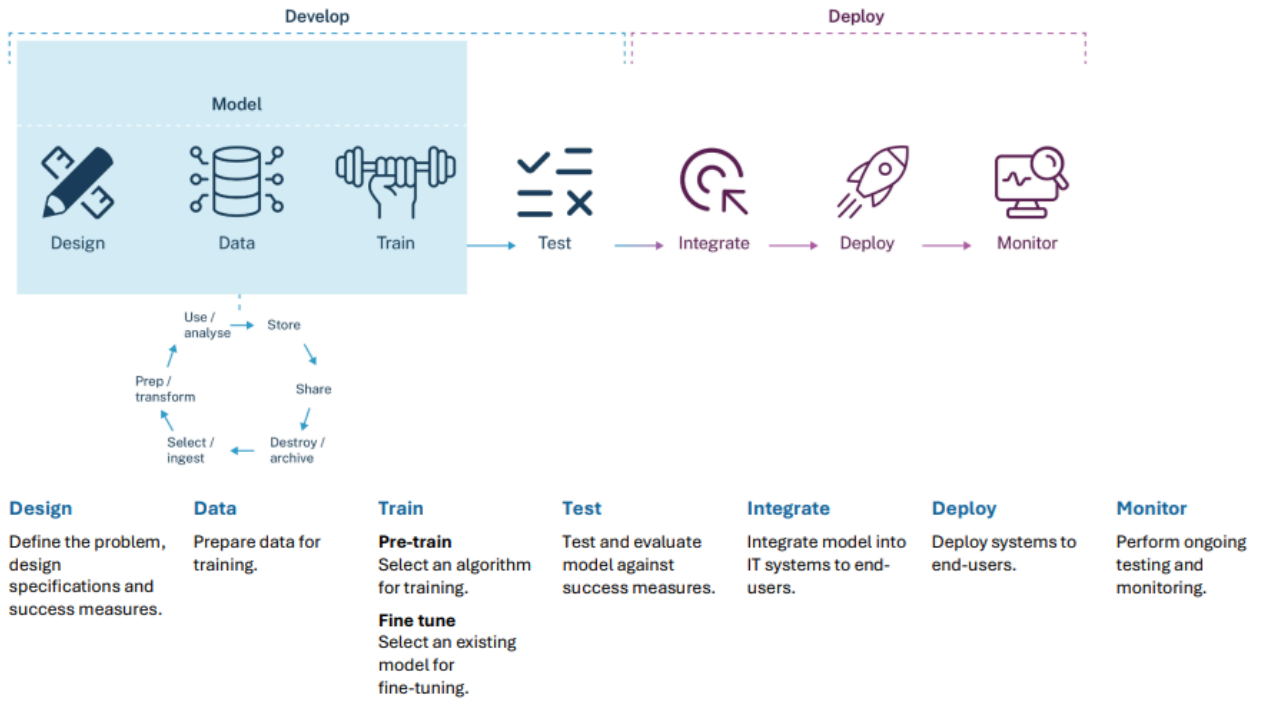
Overview

Who is this guidance for?

This guidance is targeted at organisations that are deploying AI systems that were built with, collect, store, use or disclose personal information. A **'deployer'** is any individual or organisation that supplies or uses an AI system to provide a product or service.[1] **Deployment** can be used for internal purposes or used externally impacting others, such as customers or individuals, who are not deployers of the system. If your organisation is using AI to provide a product or service, including internally within your organisation, then you will be a deployer.

This guidance is intended to assist organisations to comply with their privacy obligations when using commercially available AI products. Common types of AI tools and products currently being deployed by Australian entities include chatbots, content-generation tools (including text-to-image generators), and productivity assistants that augment writing, coding, note-taking, and transcription. While most of the content in the guidance is specific to situations in which an organisation considers purchasing an AI product, it also addresses the use of AI products which are freely available, such as publicly accessible AI chatbots.

The OAIC has separate guidance on privacy and developing and training generative AI models.



Source: Department of Industry, Science and Resources, *Safe and responsible AI in Australia: Proposals paper for introducing mandatory guardrails for AI in high-risk settings*, September 2024.

How to use this guidance

This guidance is not intended to be a comprehensive overview of all relevant privacy risks and obligations that apply to the use of AI. It aims to highlight the key privacy considerations and APP requirements that your business should have in mind when selecting and using an AI product. It does not address considerations from other regulatory regimes that may apply to the use of AI systems.[2]

While the Privacy Act applies to all uses of AI which involve the handling of personal information, **this guidance will be particularly useful in relation to the use of generative AI tools and general-purpose AI tools** involving personal information, as well as other uses of AI with a high risk of adverse impacts.

It is important to recognise that generative AI systems may carry particular privacy risks due to their probabilistic nature, reliance on large amounts of training data and vulnerability to malicious uses.[3] However, a number of significant privacy risks can arise in relation to both traditional and generative AI systems, depending on the design and use. It can also be difficult for users to clearly distinguish between generative and traditional AI systems, which can sometimes contain similar features. Further, in some use cases, generative and traditional AI are being combined – for example, in the marketing context traditional AI can be used to identify customer segments for personalised campaigns, with generative AI then used to create the personalised marketing content.

Organisations should therefore take a proportionate and risk-based approach to the selection and use of any AI products. This guidance sets out questions aimed at assisting your organisation with this process.

This guidance does not have to be read from start to finish – you can use the topic headings to navigate to the sections of interest to you. Most sections conclude with a list of practical tips, which draw together the key learnings from each section. We have also included case studies and examples in each section to illustrate the way that the APPs may apply.

Finally, there is a Quick Reference Guide and two Checklists to help guide your business in the selection and use of AI products and summarise the obligations discussed.

Introductory terms

While there is no single agreed definition of artificial intelligence (AI), as a general term it refers to the ability of machines to perform tasks which normally require human intelligence.[4] Although AI has existed in different forms for many decades, there have been significant technological advances made in recent years which have led to the emergence of AI models which apply advanced machine learning to increasingly sophisticated uses. [5]

More technically, AI refers to 'a machine-based system that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments'. Different AI systems vary in their levels of autonomy and adaptiveness after deployment'.[6] An **AI *model*** is the 'raw, mathematical essence that is often the 'engine' of AI applications' such as GPT-4, while an **AI *system*** is 'the ensemble of several components, including one or more AI models, that is designed to be particularly useful to humans in some way' such as the ChatGPT app.[7]

There are many different kinds of AI.[8] **General-purpose AI** is a type of AI model that is capable of being used, or capable of being adapted for use, for a variety of purposes, both for direct use as well as for integration in other systems.[9] ChatGPT and DALL-E are examples of general-purpose AI systems (as well as being generative AI, see further below). There are also **narrow AI** models, which are focused on defined tasks and uses to address a specific problem.[10] Examples of narrow AI systems include AI assistants such as Apple's Siri or Google Assistant, and many facial recognition tools.

Generative AI refers to 'an AI model with the capability of learning to generate content such as images, text, and other media with similar properties to its training data' and systems built on such models.[11] **Large language models** (LLMs) and **multimodal foundation models** (MFMs) are both examples of generative AI. An LLM is 'a type of

generative AI that specialises in the generation of human-like text'.[12] Some examples of products or services incorporating LLMs are Meta AI Assistant, ChatGPT, Microsoft Copilot and HuggingChat.[13]

An MFM is 'a type of generative AI that can process and output multiple data types (e.g. text, images, audio)'.[14] Some examples of products or services incorporating MFMs that are image or video generators include DALL-E 3, Firefly, Jasper Art, Synthesia, Midjourney and Stable Diffusion. Some examples of products or services incorporating MFMs that are audio generators include Riffusion, Suno, Lyria and AudioCraft.



Artificial intelligence and privacy

Artificial intelligence (AI) has the potential to benefit the Australian economy and society, by improving efficiency and productivity across a wide range of sectors and enhancing the quality of goods and services for consumers.[15] However, the data-driven nature of AI technologies, which rely on large data sets that often include personal information, can also create new specific privacy risks, amplify existing risks and lead to serious harms.[16]

It is important that organisations understand these potential risks when considering the use of commercially available AI products. Entities that choose to use AI need to:

- Consider whether their development involved (or their use will involve) personal information
- If they involve the processing of personal information, ensure that they embed privacy into their systems both when selecting and using AI products.

Existing AI systems can perform a range of tasks such as:

- automatically summarising information or documents
- undertaking data analysis
- providing customer services
- producing content (including editing or creating images, video and music)
- generating code, such as through the use of AI coding assistants, and
- providing speech translation and transcription.[17]

These applications are continuing to change and expand as the technologies develop.

The risks of AI will differ depending on the particular use case and the types of information involved. For example, the use of AI in the healthcare sector may pose particular privacy risks and challenges due to the sensitivity of health information.

How does the Privacy Act apply?

The *Privacy Act 1988* and the Australian Privacy Principles (APPs) apply to all uses of AI involving personal information, including where information is used to train, test or use an AI system. If your organisation is covered by the Privacy Act, you will need to understand your obligations under the APPs when using AI. This includes being aware of the different ways that your organisation may be collecting, using and disclosing personal information when interacting with an AI product.

What is personal information?

Personal information includes a broad range of information, or an opinion, that could identify an individual. This may include information such as a person's name, contact details and images or videos where a person is identifiable. What is personal information will vary, depending on whether a person can be identified or is reasonably identifiable in the circumstances. Personal information is a broad concept and includes information which can reasonably be linked with other information to identify an individual.

Sensitive information is a subset of personal information that is generally afforded a higher level of privacy protection. Examples of sensitive information include photographs or videos where sensitive information such as race or health information can be inferred, as well as information about an individual's political opinions or religious or philosophical beliefs.

Importantly, information can be personal information whether or not it is true. This may include false information generated by an AI system, such as hallucinations or deepfakes. [18]

Privacy risks and harms

The use of both traditional and generative AI technologies carries a number of significant privacy risks. Specific risks are discussed throughout this guidance, but can include:

- **Bias and discrimination**: As AI systems learn from source data which may contain inherent bias, this bias may be replicated in their outputs through inferences made based on gender, race or age and have discriminatory effects.[19] AI outputs can often appear credible even when they produce errors or false information.
- **Lack of transparency**: The complexity of many AI systems can make it difficult for entities to understand and explain how personal information is used and how decisions made by AI products are reached. In some cases, even developers of AI models may not fully understand how all aspects of the system work. This creates significant challenges in ensuring the open and transparent handling of personal information in relation to AI systems.[20]

- **Risk of disclosure of personal information through a data breach:** The vast amounts of data collected and stored by many AI models, particularly generative AI, may increase the risks related to data breaches.**[21]** This could be through unauthorised access to the training dataset or through attacks designed to make a model regurgitate its training dataset.[22]
- **Individuals losing control over their personal information**: Many generative AI technologies are trained on large amounts of public data, including the personal information of individuals, which is likely to be collected without their knowledge and consent.[23] It can be difficult for individuals to identify when their personal information is used in AI systems and to request the correction or deletion of this information. These risks will also arise in relation to some traditional AI systems which are trained on public data containing personal information, such as facial recognition systems.

Generative AI can carry particular privacy risks, such as the following:

- **Misuse of generative AI systems**: The capabilities of AI models can be misused through malicious actors building AI systems for improper purposes, or the AI model or end users of AI systems misusing them, with potential impacts on individual privacy or broader negative consequences including through:[24]
  - Generating disinformation at scale, such as through deepfakes
  - Scams and identity theft
  - Generating harmful or illegal content, such as image-based abuse, which can be facilitated through the accidental or unintended collection and use of harmful or illegal material, such as child sexual abuse material, to train AI systems[25]
  - Generating harmful or malicious code that can be used in cyber attacks or other criminal activity.
- **Other inaccuracies**: Issues in relation to accuracy or quality of the training data (including as a result of data poisoning)[26] and the predictive nature of generative AI models can lead to outputs that are inaccurate but appear credible. [27] Feedback loops can cause the accuracy and reliability of an AI model to degrade over time.[28] Inaccuracies in output can have flow on consequences that depend on the context, including reputational harm, misinformation or unfair decisions.

Example – AI chatbot regurgitating personal information

A work health and safety training company used an AI chatbot to generate fictional scenarios of psychosocial hazards to be used in a course delivered at an Australian prison. One of the ‘fictional’ case studies generated by the chatbot was in fact a real scenario involving a former employee of the prison, and included the full names of persons involved as well as details from an ongoing court case.[29]

This example highlights the risks of AI systems regurgitating personal information from their training data even when prompted for fictional examples, creating a range of potential

privacy compliance and ethical risks. This risk can be exacerbated when the system has been trained on limited data relevant to the prompt.

Organisations should be mindful that the impacts of the use of AI systems may be particularly acute for children and people experiencing vulnerability. There are well-publicised examples of discrimination against individuals as a result of algorithmic bias in AI systems.[30] Vulnerable groups, including First Nations people, will often not be properly represented in datasets which reflect historical biases or do not include sufficient data.[31]



Interaction with Voluntary AI Safety Standard

The National AI Centre has developed a Voluntary AI Safety Standard to help organisations develop and deploy AI systems in Australia safely and reliably. The standard consists of 10 voluntary guardrails that apply to all organisations across the AI supply chain. It does not seek to create new legal obligations, but rather helps organisations deploy and use AI systems in accordance with existing Australian laws. The information in this guidance is focussed on compliance with the Privacy Act, but will also assist organisations in addressing the guardrails in the Standard. For more information, see: www.industry.gov.au/publications/voluntary-ai-safety-standard. - external site



What should organisations consider when selecting an AI product?

When looking to adopt a commercially available AI product, your organisation must ensure that it has enough information to understand how the product works and the potential risks involved, including in relation to privacy. Failing to conduct appropriate due diligence may create a range of risks, including that your organisation will deploy a product which is unsuited to its intended uses and does not produce accurate responses.

Practising ‘privacy by design’ is the best way to ensure your organisation engages with AI products in a responsible way that protects personal information and maintains trust in your products or services. This means building the management of privacy risks into your systems and processes from the beginning, rather than at the end.

A Privacy Impact Assessment will assist your organisation to understand the impact that your use of a particular AI product may have on the privacy of individuals and identify ways to manage, minimise or eliminate those impacts. For more information, see our Guide to

undertaking privacy impact assessments and our Undertaking a privacy impact assessment e-learning course.

The following are matters which should be considered when selecting an AI product. This is focused on privacy-related issues and is not a comprehensive list – organisations should consider whether there are obligations or due diligence requirements arising from other frameworks which may also be relevant.

Is the product appropriate for its intended uses?

When selecting an AI product, your organisation should clearly identify the ways it intends to use AI and evaluate whether the particular product is appropriate. This includes considering whether the product has been tested and proven for such uses.

You should consider whether the intended uses are likely to constitute high privacy risk activities. This may be the case, for example, if the AI system will be used in relation to making decisions that may have a legal or similarly significant effect on an individual's rights. In circumstances of high privacy risk, it is particularly important to ensure the appropriateness of the product for the intended purpose. This will include considering whether the behaviour of the AI system can be understood or explained clearly by your organisation.

To meet your organisation's privacy obligations, particularly with respect to accuracy under APP 10, you should ensure you understand what data sources the AI system has been trained on, to assess whether the training data will be sufficiently diverse, relevant and reliable for your organisation's intended uses. This will also help you to understand the potential risks of bias and discrimination. For example, if the AI product has not been trained on Australian data sets you should consider whether your organisation's use of the product is likely to comply with your accuracy obligations under APP 10. Before deploying AI products, particularly customer-facing products such as chatbots, you should carefully test them to understand the risks of inaccurate or biased answers.

You should take steps to understand the limitations of the system as well as the protections that the developer has put in place. However, while developers may implement mitigations or safeguards to address these limitations – such as to prevent an AI system from producing or 'surfacing' personal information in its output - these will not be foolproof. Your business will need to implement its own processes to ensure the use of AI complies with your privacy obligations – these are discussed further below.

If your organisation intends to fine-tune an existing AI system for your specific purposes, the OAIC's guidance on developing and training generative AI models sets out further privacy considerations and requirements.

For more information about your accuracy obligations under APP 10, see ‘What obligations do we have to ensure the accuracy of AI systems?’ below.

Example – Accuracy considerations when selecting an AI product

AI technology is increasingly being applied to healthcare, from AI-generated diagnostics to algorithms for health record analysis or disease prediction.[32] While AI may have potential benefits for healthcare, users should be aware of the potential for bias and inaccuracy. For example, an AI algorithm that has been trained with data from Swiss patients may not perform well in Australia, as patient population and treatment solutions may differ.

The impact of an algorithm applying biased information may lead to worsening health inequity for an already vulnerable section of the population or supply incorrect diagnoses.[33] It is important that your organisation is aware of how the AI software was developed, including the source data used to train and fine-tune the model, to ensure it is appropriate for your intended use.

What are the potential security risks?

When assessing a new product, you should consider your organisation’s obligations under APP 11 to take reasonable steps to protect the personal information you hold from misuse, interference and loss, as well as unauthorised access, modification or disclosure. You should take active steps to ensure that the use of an AI system will not expose your organisation’s personal information holdings to additional security risks.

Consider the general safety of the product, including whether there are any known or likely security risks. It may be helpful to run a search for any past security incidents. You should also assess what security measures have been put in place by the product owner to detect and protect against threats and attacks. For example, you may consider whether a generative AI product fine-tuned with your organisation’s data has been developed to block malicious or unlawful queries intended to make the product regurgitate its training data.

Organisations should also think about the intended operating environment for the AI product. For example, if a generative AI product is to be integrated into the organisation’s systems and have access to its documents then you will need to consider whether this will occur within a secure environment on the entity’s premises or hosted through the cloud. If the generative AI system will be deployed through the cloud, it will be necessary to consider the security and privacy risks of this, including where the servers are located and whether personal information could be disclosed outside of Australia. Deploying a system locally or on premises is likely to be more privacy-preserving as it limits the risks of third party access to the data.

For example, an AI coding assistant may be used to assist with software development such as by taking over recurring tasks in the development process, formatting and

documenting code, and supporting debugging. Despite these benefits, studies have shown that programs generated by coding assistants often carry security vulnerabilities and the coding assistants themselves are vulnerable to malicious attacks.[34] When considering deployment of an AI coding assistant tool that may handle (or otherwise have access to) personal information, organisations should undertake a risk analysis and put in place appropriate mitigation measures where necessary.

Who will have access to data in the AI system?

Carefully review the terms and settings which will apply to your organisation's use of the product. In particular, you should understand whether the service terms provide the developer with access to data which your organisation inputs or generates when using the AI. If it does, you will need to consider whether the use of the product will be compliant with your privacy obligations, particularly APP 6 which restricts the disclosure of personal information for secondary purposes.

Some commercial AI products will include terms or settings that allow the product owner to collect the data input by customers for further training and development of AI technologies. This can create privacy risks, with the potential for personal information input into an AI product then surfacing in response to a prompt from another user. You should also consider whether a third party receives personal information through the operation of the commercial AI product. For example, some commercial generative AI products have interfaces with search engines or other features that would result in disclosure of personal information entered in prompts to a third party.

If the operation or features of the AI system require disclosure of personal information to the developer or third parties, you will need to consider whether it is appropriate to proceed with using the product and if so, what measures should be placed around your use of the system to ensure you comply with APP 6. Relevant measures could include turning off features that would disclose personal information, providing any required notice of disclosure to the individual, controls to prevent personal information from being entered or prohibiting your staff from entering personal information in the AI inputs. Any controls or prohibitions on including personal information in AI inputs will need to be accompanied by robust training and auditing measures.

For more information on your APP 6 obligations when using AI systems, see 'Can we input personal information into an AI system, such as through a prompt in an AI chatbot?' below.

Practical tips – privacy considerations when selecting an AI product

When choosing an AI product, your organisation must conduct due diligence and ensure you identify potential privacy risks. You should be able to answer the following questions:

- How does your organisation plan to use the AI product? What is the potential privacy impact of these uses?
- What data has the product been trained and tested on? Is this training data diverse and relevant to your business, and what is the risk of bias in its outputs?
- What are the limitations of the system, and has the developer put in place safeguards to address these?
- What is the intended operating environment for the product? Are there any known or likely security risks?
- What are the data flows in the AI product? Will the developer or other third parties have access to the data which your organisation inputs or generates when using the AI product? Can you turn these features off or take other steps to comply with privacy obligations?

Conducting a **Privacy Impact Assessment** may assist you with considering these questions.



What are the key privacy risks when using AI?

When using AI products, organisations should be aware of the different ways that they may be handling personal information and of their privacy obligations in relation to this information. It is important to understand the specific risks associated with your organisation's intended uses of AI, and whether or how they can be managed and mitigated.

Organisations should always consider whether the use of personal information in relation to an AI system is necessary and the best solution in the circumstances. AI products should not be used simply because they are available.

Key privacy considerations are set out below in relation to both the data ***input*** into an AI system, and the ***output*** data generated by AI.

Can we input personal information into an AI system?

The sharing of personal information with AI systems may raise a number of privacy risks. Once personal information has been input into AI systems, particularly generative AI products, it will be very difficult to track or control how it is used, and potentially impossible to remove the information from the system.[35] The information may also be susceptible to various security threats which aim to bypass restrictions in the AI system, or may be at risk of re-identification even when de-identified or anonymised.

It is therefore important that your business proceeds cautiously before using personal information in an AI prompt or query, and only does so if it can comply with APP 6.

What are the requirements of APP 6?

When personal information is input into an AI system, it may be considered either a ***use*** of personal information (if the data stays within your organisation's control) or a ***disclosure*** of personal information (if the data is made accessible to others outside the organisation and has been released from your organisation's effective control) under the Privacy Act. The use and disclosure of personal information must comply with APP 6.

APP 6 provides that an individual's personal information can only be used or disclosed for the purpose or purposes for which it was collected (known as the 'primary purpose') or for a secondary purpose if an exception applies. Common exceptions include where:

- the individual has consented to a secondary use or disclosure, or
- the individual would reasonably expect the entity to use or disclose their information for the secondary purpose, and that purpose is related to the primary purpose of collection (or in the case of sensitive information, directly related to the primary purpose).

Your organisation should identify the anticipated purposes for which you will use personal information in connection with an AI system, and whether these are the same as the purposes for which you collected the information. If you intend to use personal information in AI systems for other, secondary purposes, you should consider whether these will be authorised by one of the exceptions under APP 6.

As outlined in the example below, organisations should frame purposes for collection, use and disclosure narrowly rather than expansively. However, it can be helpful to distinguish between the use of AI which is facilitative of, or incidental to a primary purpose (such as the use of personal information as part of customer service, where AI is the tool used), from purposes which are directly AI-related (such as the use of personal information to train an AI model).

Example – Can an organisation enter personal information into a publicly available generative AI chatbot?

Employees at an insurance company experiment with using a publicly available AI chatbot to assist with their work. They enter the details of a customer's claim – including the customer's personal and sensitive health information – into the chatbot and ask it to prepare a report assessing whether to accept the claim.

By entering the personal information into the AI chatbot, the insurance company is disclosing the information to the owners of the chatbot. For this to comply with APP 6, the insurance company will have to consider whether the purpose for which the personal

information was disclosed is the same as the primary purpose for which the information was collected. This should have been specified in a notice provided to the customer at the time of collection in accordance with APP 5.

How broadly a purpose can be described will depend on the circumstances, however in cases of ambiguity, the OAIC considers that the primary purpose for collection, use or disclosure should be construed narrowly rather than expansively.[36]

If the purpose of disclosure is not consistent with the primary purpose of collection, the company will need to assess whether an exception under APP 6 applies. If the company wants to rely on the 'reasonable expectations' exception under APP 6.2(a), they must establish that the customer would reasonably have expected their personal information to be disclosed for the relevant purpose. The company should consider whether their collection notice and privacy policy specify that personal information may be disclosed to AI system developers or owners, in accordance with APP 5. It may be difficult to establish reasonable expectations if customers were not specifically notified of these disclosures, given the significant public concern about the privacy risks of chatbots.

It is important to be aware that an organisation seeking to input personal information into AI chatbots will also need to consider a range of other privacy obligations, including in relation to the generation or collection of personal information (APP 3), accuracy of personal information (APP 10) and cross-border disclosures (APP 8).

Given the significant and complex privacy risks involved, as a matter of best practice it is recommended that organisations do not enter personal information, and particularly sensitive information, into AI chatbots.

When will an individual reasonably expect a secondary use of their information for an AI-related purpose?

If your organisation is seeking to rely on the 'reasonable expectations' exception to APP 6, you should be able to show that a reasonable person who is properly informed would expect their personal information to be used or disclosed for the proposed secondary purpose.

You should consider whether the proposed use would have been within the reasonable expectations of the individual at the time the information was collected. This may be the case if the secondary use was expressly outlined in a notice at the time of collection and in your organisation's privacy policy.

Whether APP 5 notices or privacy policies were updated, or other information was given at a point in time after the collection, may also be relevant to this assessment. It is possible for an individual's reasonable expectations in relation to secondary uses to change over time. However, particular consideration should be given to the reasonable expectations at the time of collection, given this is when the primary purpose is determined.

Given the significant privacy risks that may be posed by AI systems, and strong levels of community concern around the use of AI, in many cases it will be difficult to establish that a secondary use for AI-related purposes (such as training an AI system) was within reasonable expectations.

If your organisation cannot clearly establish that a secondary use for an AI-related purpose was within reasonable expectations and related to the primary purpose, to avoid regulatory risk you should seek consent for that use and/or offer individuals a meaningful and informed ability to opt-out.

Importantly, you should only use or disclose the minimum amount of personal information sufficient for the secondary purpose. The OAIC expects organisations to consider what information is necessary and assess whether there are ways to minimise the amount of personal information that is input into the AI product. It may be helpful to consider whether there are privacy-preserving techniques that you could use to minimise the personal information included in the relevant prompt or query without compromising the accuracy of the output.

Further information about APP 6 requirements and exceptions is in the APP Guidelines at Chapter 6: APP 6 Use or disclosure of personal information.

Example – Can our organisation use existing customer data with an AI system?

Your organisation may have existing information that you wish to input into a new AI product. For example, you may plan to use AI to assist with your customer service functions, such as providing tailored marketing recommendations. To do so, the AI system needs to run individual analysis on your customer data.

If your organisation is using a proprietary AI system rather than a publicly available chatbot, for example, and has protections in place to ensure that information entered into the system will not be disclosed outside the organisation (such as to the system developer), this will constitute a use rather than a disclosure of personal information.

To assess whether your organisation's proposed use of customer data will be compliant with your APP 6 obligations, you should consider the purposes for which the information was collected. This should have been specified in a notice provided to the customer at the time of collection in accordance with APP 5.

If one of the primary purposes of collection was providing tailored marketing recommendations, the proposed use of AI to assist with this analysis is likely consistent with the primary purpose. As discussed above, how broadly a purpose can be described will depend on the circumstances, however in cases of ambiguity, the OAIC considers that the primary purposes of collection, use or disclosure should be construed narrowly rather than expansively.[38]

Your organisation then wishes to use the customer data you hold to further fine-tune the AI system you are using. If the customer's personal information was not collected for this purpose, you will need to either obtain the customer's consent to use the information in this way or establish that the reasonable expectations exception under APP 6.2(a) applies. To establish reasonable expectations, you should consider whether you have notified the individual that their personal information would be used in this way, such as via your organisation's APP 5 notices and privacy policy.

Further OAIC guidance on the development and training of generative AI models.

Practical tips – using or disclosing personal information as an AI input

If your organisation wants to use personal information as an input into an AI system, you should consider your APP 6 obligations:

- Is the purpose for which you intend to use or disclose the personal information the same as the purpose for which you originally collected it?
- If it is a secondary use or disclosure, consider whether the individual would reasonably expect you to use or disclose it for this secondary purpose. What information have you given them about your intention to use their personal information in this way?
- If it is a secondary use or disclosure, also consider whether the secondary purpose is related to the primary purpose of collection (or if the information is sensitive information, whether it is directly related to the primary purpose).
- Take steps to minimise the amount of personal information that is input into the AI system.

Given the significant and complex privacy risks involved, as a matter of best practice it is recommended that organisations do not enter personal information, and particularly sensitive information, into publicly available AI chatbots.

What privacy obligations apply if we use AI to collect or generate personal information?

Can we collect personal information through an AI chatbot?

If your organisation collects personal information through public facing AI systems, such as through the use of AI chatbots, this collection must comply with APP 3 and APP 5 requirements. For example, if you have a customer facing AI chatbot on your website and you collect the information your customers send to the chatbot, you will need to ensure this collection complies with APP 3. In particular, APP 3 requires the collection of personal information to be reasonably necessary for your entity's functions or activities and to be carried out by lawful and fair means.

The requirements of APP 3 are discussed under '***Can we use an AI product to generate or infer personal information?',*** directly below.

As part of your entity's APP obligations in relation to transparency and ensuring the collection of personal information is lawful and fair, you should make sure that individuals are made aware that they are interacting with an AI system rather than a human. Your entity will also need to comply with your APP 5 obligations by taking reasonable steps to notify individuals about certain matters in relation to the collection of their personal information.

Can we use an AI product to generate or infer personal information?

Where you use AI to infer or generate personal information, the Privacy Act will treat this as a 'collection' of personal information and APP 3 obligations will apply. Under the Privacy Act, the concept of collection applies broadly, and includes gathering, acquiring or obtaining personal information from any source and by any means, including where information is created with reference to, or generated from, other information an entity holds.[38] To meet your APP 3 obligations when using AI, you must ensure that:

- any personal information generated by an AI product is reasonably necessary for your business's functions or activities;
- the use of AI to infer or generate personal information is only by lawful and fair means; and
- it would be unreasonable or impracticable to collect the personal information directly from the individual.

If you are using AI to generate or infer sensitive information about a person, you will also need to obtain that person's consent to do so (unless an exception applies).

If personal information is created through the use of AI which your organisation is not permitted to collect under APP 3, it will need to be destroyed or de-identified.

The use of AI systems to infer personal information, such as making inferences about a person's demographic information or political views based on data from their social media, creates risks by enabling organisations to generate and use personal information that has not been knowingly disclosed by the individual, including information which may not be accurate.

Generating personal information through AI will also attract other APP obligations, including in relation to providing notice to individuals (APP 5) and ensuring the accuracy of personal information (APP 10). These obligations are discussed under the 'Transparency' and 'Accuracy' sections of this guidance.

Using sensitive information in relation to AI products

Sensitive information is a subset of personal information that is generally afforded a higher level of privacy protection under the APPs. Examples of sensitive information include photographs or videos where sensitive information such as race or health information can be inferred, as well as information about an individual's political opinions or religious or philosophical beliefs.

It is important that organisations using AI products identify whether they may be collecting sensitive information in connection with these systems. For example, AI image and text manipulators can generate sensitive biometric information, including information that may be false or misleading.

If you use AI to generate or collect sensitive information about a person, to comply with APP 3 you will usually need to obtain consent.[39] Consent goes beyond just a line in your Privacy Policy - you must make sure that the individual is fully informed of the risks of using or generating sensitive information, and this consent must be current and specific to the circumstances that you are using it in.[40]

Organisations cannot infer consent simply because you have provided individuals with notice of a proposed collection of personal information.

When is generating personal information 'reasonably necessary'?

What is 'reasonably necessary' for the purposes of APP 3 is an objective test based on whether a reasonable person who is properly informed would agree that the collection is necessary. You should consider whether the type and amount of personal information you are seeking to obtain from the AI system is necessary, and whether your organisation could pursue the relevant function or activity without generating the information (or by generating less information).

If there are reasonable alternatives available, the use of AI in this way may not be considered reasonably necessary.

What will constitute 'lawful and fair means'?

Using AI to generate personal information may not be lawful for the purposes of APP 3 if it is done in breach of legislation – this would include, for example, generating or inferring information in connection with, or for the purpose of, an act of discrimination.[41]

For the purposes of APP 3, the collection or generation of personal information using AI may be unfair if it is unreasonably intrusive, or involves intimidation or deception.[42] This will depend on the circumstances. However, it would usually be unfair to collect personal information covertly without the knowledge of the individual.[43]

For example, organisations seeking to use AI to generate or infer personal information based on existing information holdings for a customer, in circumstances where the

customer is not aware of their personal information being collected in this way, should give careful consideration as to whether this is likely to be lawful and fair.

In considering whether the generation of personal information has been fair, it may also be relevant to consider whether individuals have been given a choice. The OAIC encourages entities to provide individuals with a meaningful opportunity to opt-out of having their personal information processed through AI syste

Example – can our business use AI to take meeting minutes?

Commonly available virtual meeting platforms can record meetings and use AI to generate transcripts or written minutes. To comply with APP 3, it is important that you carefully consider the content of the meeting discussion, and ensure that any personal information collected is reasonably necessary to your organisation's functions or activities. If you find that your system recorded any personal or sensitive information that is not reasonably necessary, such as a personal conversation or confidential client information, you will need to ensure that the information is destroyed or de-identified.

You will also need to obtain consent from participants if the AI system collects sensitive information. Given the uncertainty of what may be discussed in a meeting, seeking consent should be pursued as a matter of best practice. Depending on the circumstances, this could be done by advising meeting attendees of the AI system being in use and providing them with the option to object at the outset. However, this approach will only be appropriate if the information about the system and opt-out option is clear and prominent to all attendees so that it is likely they will have seen and read it, and where the consequences for failing to opt-out are not serious.[44]

Whether the participants in the meeting are made aware of the meeting being recorded and a transcript being produced, and whether consent is given to this occurring, will also be relevant factors in considering whether the AI product's collection of personal information is by lawful and fair means.[45]

Could the information be collected directly from the individual?

If you are generating personal information through an AI product, to ensure you comply with APP 3 your organisation must be able to show that it would be unreasonable or impracticable to collect this information directly from the individual.[46]

What is 'unreasonable or impracticable' will depend on circumstances including whether the person would reasonably expect personal information about them to be collected directly from them, the sensitivity of the personal information being generated by the AI system, and the privacy risks of collecting the information through the use of the particular AI product. While the time and cost involved of collecting directly from the individual may also be a factor, organisations will need to show the burden is excessive in all the circumstances.[47]

Given the risks posed by AI systems, it may be difficult to establish that it was unreasonable or impracticable to collect personal information directly from a customer with whom your organisation has an ongoing relationship, particularly where the AI system is used to generate or infer sensitive information about the customer.

Practical tips – using AI to collect or generate personal information

If your organisation is collecting personal information through an AI system such as a chatbot, or using an AI product to generate or infer personal information, you should consider your APP 3 obligations:

- Ensure the collection or generation is reasonably necessary for your organisation's functions or activities.
- Consider whether you are collecting or generating personal information only by lawful and fair means.
- Consider whether it would be unreasonable or impracticable to collect the information directly from the person.
- If you are collecting or generating sensitive information using AI, make sure you have the individual's consent.

What obligations do we have to ensure the accuracy of AI systems?

Organisations subject to the Privacy Act must comply with their accuracy obligations under APP 10 when using AI systems. APP 10 requires entities to take reasonable steps to ensure that:

- the personal information they collect is accurate, up-to-date and complete; and
- the personal information they use and disclose is, having regard to the purpose of the use or disclosure, accurate, up-to-date, complete and relevant.

As discussed elsewhere in this guidance, AI technologies carry inherent accuracy risks. Both traditional and generative AI models built on biased or incomplete information can then perpetuate and amplify those biases in their outputs, with discriminatory effects on individuals. Developers of AI systems may also unknowingly design systems with features that operate in biased ways.

What are the specific accuracy risks of generative AI?

Accuracy risks are particularly relevant in the context of generative AI. There are a number of factors which contribute to this:

- Generative AI models such as large language models (LLMs) are trained on huge amounts of data sourced from across the internet, which is highly likely to include inaccuracies and built-in biases.

- The probabilistic nature of generative AI (in which the next word, sub-word, pixel or other medium is predicted based on likelihood) and the way it tokenises input can generate hallucinations. For example, without protective measures an LLM asked how many 'b's are in banana will generally state there are two or three 'b's in banana as the training data is weighted with instances of people asking how many 'a's or 'n's are in banana and because of the way it tokenises words not letters.[48]
- The accuracy and reliability of an AI model is vulnerable to deterioration over time. This can be caused by the accumulation of errors and misconceptions across successive generations of training, or by a model's development on training data obtained up to a certain point in time, which eventually becomes outdated.[49]
- An LLM's reasoning ability declines when it encounters a scenario or task that differs to what is in their training data.[50]

These risks can be compounded by the tendency of generative AI tools to confidently produce outputs which appear credible, regardless of their accuracy. Generative AI also has the potential to emulate human-like behaviours and generate realistic outputs, which may cause users to overestimate its accuracy and reliability.

What are the requirements of APP 10?

Organisations looking to use AI must be aware of these accuracy risks and how they may impact on the organisation's ability to comply with their privacy obligations. As discussed above, APP 10 requires an entity to take reasonable steps to ensure that:

- the personal information it collects is accurate, up-to-date and complete; and
- the personal information it uses and discloses is accurate, up-to-date, complete and relevant, having regard to the purpose of the use or disclosure.

The reasonable steps that an organisation should take will depend on circumstances that include the sensitivity of the personal information, the nature of the organisation holding the personal information, and the possible adverse consequences for an individual if the quality of personal information is not ensured.[51]

There are a number of measures which organisations should consider when seeking to ensure the accuracy of AI outputs. Some examples of these are set out below. However, given the significant accuracy risks associated with AI, and its potential to be used to make decisions that may have a legal or similarly significant effect on an individual's rights, it is possible that these measures may not always be sufficient to constitute 'reasonable steps' for the purposes of APP 10.

How an organisation intends to use outputs from an AI system will also be relevant to the accuracy required. When using a generative AI system for example, if it intends to use the outputs as probabilistic guesses about something that may or may not be true rather than factually accurate information about an individual and this is in a low-risk context, 100%

statistical accuracy may not be required. To comply with your APP 10 obligations, you should design your processes to factor in the possibility that the output is not correct. You should also not record or treat these outputs as facts but ensure that your records clearly indicate that they are probabilistic assessments and identify the data and AI system used to generate the output.

When considering potential uses of AI products, organisations should carefully consider whether it will be possible to do so in a way that complies with their privacy obligations in respect of accuracy.

Example – AI in recruiting

Your organisation may wish to use AI for recruiting purposes, such as to source and screen candidates, analyse resumes and job applications and conduct pre-employment assessments. Given the known risk of AI systems producing biased or inaccurate results, including in relation to recruitment, [52] you should consider whether the use of AI is necessary and the best option in the circumstances. If you do use AI to assist with recruitment, you must implement controls to ensure that outputs are accurate and not biased and that the risk of any inaccuracy is considered.

Controls should include assessing the particular AI product and how it has been trained, to ensure that it is appropriate for the intended uses (see 'Selecting an AI product' above). You should also ensure that there is human oversight of the AI system's processes, and that staff are appropriately trained and able to monitor for any inaccurate outputs. This should include periodic assessments of the AI output to identify potential biases or other inaccuracies.

Practical tips – accuracy measures

To comply with your APP 10 obligations, your organisation must take reasonable steps to ensure the accuracy of the personal information it collects, generates, uses and discloses when using an AI product. You should think about:

- Ensuring that any AI product used has been tested on and is appropriate for the intended purpose, including through the use of training data which is sufficiently diverse and relevant.
- Taking steps to verify that the data being input into, or used to train or develop the AI product is accurate and of a high quality – this may include reviewing your organisation's data holdings and ensuring you have processes in place to review and maintain data quality over time.
- Ensuring that your entity's records clearly indicate where information is the product of an AI output and therefore a probabilistic assessment rather than fact, as well as the data and system used to generate the AI output.

- Establishing processes to ensure there is appropriate human oversight of AI outputs, which treat the outputs as statistically informed guesses. There are varying forms and degrees of human oversight that may be possible, depending on the context of the AI system and the particular risks.[53] It is important that a human user should be responsible for verifying the accuracy of any personal information obtained through AI, and can overturn decisions made.
- Training staff to understand the design and limitations of an AI system and to anticipate when it may be misleading and why. Staff should be trained and have the necessary resources to verify input data, critically assess outputs, as well as to provide meaningful explanations for decisions they make to reject or accept the AI system's output.
- Ensuring that individuals are made aware of when AI is used in ways which may materially affect them.
- Maintaining ongoing monitoring of AI systems to ensure they are operating as intended and that unintended impacts such as bias or inaccuracies are identified and rectified.



What transparency and governance measures are needed?

Organisations subject to the Privacy Act have a number of transparency obligations:

- APP 1 requires entities to take reasonable steps to implement practices, procedures and systems to ensure they comply with the APPs, and to have a clearly expressed and up-to-date Privacy Policy.
- APP 5 requires entities that collect personal information about an individual to take reasonable steps either to notify the individual of certain matters or to ensure the individual is aware of those matters.

The complexity of AI systems, particularly large AI models such as LLMs, creates challenges for businesses in ensuring that the use of AI is open and transparent. The 'black box' problem posed by some AI technologies means that even AI developers may be unable to fully explain how a system came to generate an output.[55] This can make it difficult for businesses to communicate clearly with individuals about the way that their personal information is being processed by an AI system.

Despite these challenges, it is important that organisations take steps to ensure they are transparent about their handling of personal information in relation to AI systems. Ensuring that you manage your organisation's use of AI systems in an open and transparent way will ensure you meet your APP 1 obligations, as well as increase your accountability to your

customers, clients and members of the public, and help to build community trust and confidence.

What constitutes reasonable steps under APP 1 will depend on the circumstances, including the nature of the personal information your organisation holds and the possible adverse consequences for an individual if their personal information is mishandled – more rigorous steps may be required as the risk of adversity increases.[55]

Transparency is critical to enabling individuals to understand the way that AI systems are used to produce outputs or make decisions which affect them. Without a clear understanding of the way an AI product works, it is difficult for individuals to provide meaningful consent to the handling of their personal and sensitive information, understand or challenge decisions, or request corrections to the personal information processed or generated by an AI system. Entities must ensure that the output of AI systems, including any decisions made using AI, can be explained to individuals affected.

What practical measures can we take to promote transparency?

Organisations should establish policies and procedures to facilitate transparency, enhance accountability, and ensure good privacy governance. These may include:

- informing individuals about the use of their information in connection with AI, including through statements about the use of AI systems in their Privacy Policy.
- ensuring the entity's APP 5 notices specify any AI-related purposes for which personal information is being collected, the entity's use of AI systems to generate personal information (where applicable), as well as any disclosures of personal information in connection with AI systems.
    - If the AI system developer has access to personal information processed through the system, this is a disclosure that should be included in an APP 5 notice.
- establishing procedures for explaining AI-related decisions and outputs to affected individuals. This may include ensuring that the AI tools you use are able to be appropriate explanations of their outputs.
- training staff to understand how the AI products generate, collect, use or disclose personal information and how to provide meaningful explanations of AI outputs to affected individuals.

Example – Decision-making in AI

Your organisation may be using AI to assist in decision-making processes. For example, you may use AI software that makes predictive inferences about a person to come to a decision on a client's insurance claim, home loan application or to provide financial advice. The use of AI in relation to decisions that may have a legal or similarly significant effect on an individual's rights is likely a high privacy risk activity, and particular care should be taken in these circumstances, including consideration of the accuracy and appropriateness of the

tool for the intended purpose. In particular, if the behaviour of the AI system cannot be understood or explained clearly by your entity, it may not be appropriate to use for these purposes.

To ensure your use of AI is transparent to your clients, you should ensure that the use of personal information for these purposes is clearly outlined in your Privacy Policy.

If your organisation is using an AI product to assist in the decision-making process, you must understand how the product is producing its outputs so that you can ensure the accuracy of the decision. As a matter of best practice, you should be able to provide a meaningful explanation to your client. As discussed under 'Accuracy' below, you should ensure that a human user within your entity is responsible for verifying the accuracy of these outputs and can overturn any decisions made.

It is critical to ensure that you can provide the client with a sufficient explanation about how the decision was reached and the role that the AI product played in this process. This will enable the client to be comfortable that the decision was made appropriately and on the basis of accurate information.

Practical tips – transparency measures

Your organisation must be transparent about its handling of personal information in relation to AI systems. Key steps include:

- Informing individuals about how their personal information is used in connection with AI, including at the time you collect their information and in your organisation's Privacy Policy.
- Ensuring that your organisation has the procedures and resources in place to be able to understand and explain the AI systems you are using, and particularly how they use, disclose and generate personal information.

Taking these steps will help to meet your transparency obligations under APP 1 and APP 5 as well as enhance the accountability of your organisation and build trust in your products or services.



What ongoing assurance processes are needed?

Throughout the lifecycle of the AI product, your organisation should have in place processes for ensuring that the product continues to be reliable and appropriate for its intended uses. This will assist your organisation to comply with the requirement under APP 1 to take reasonable steps to implement practices, procedures and systems that will

ensure it complies with the APPs and is able to deal with related inquiries and complaints. This should include:

- putting in place internal policies for the use of AI which clearly define the permitted and prohibited uses;
- establishing clear processes for human oversight and verification of AI outputs, particularly where the outputs contain personal information or are relied on to make decisions in relation to a person;
- provide for regular audits or monitoring of the output of the product and its use by the organisation; and
- training staff in relation to the specific product, including how it functions, its particular limitations and risks, and the permitted and prohibited uses.

Example – Importance of ongoing monitoring of embedded AI tools

Your organisation implements the use of an AI assistant called ‘Zelda’ which performs a range of tasks, including generating summaries of customer interactions, providing information on request, and editing written work. Zelda takes on the tone of a friendly colleague and staff find the tool very useful for their work.

Over time, as the model’s underlying processes and training data become outdated, Zelda increasingly produces errors in its output. Unless your organisation has robust processes in place to provide human oversight and review of these outputs, ensure the tool remains fit for purpose, and train staff to understand its limitations, there is a risk that staff will come to over-rely on the assistant and overestimate its accuracy, leading to potential compliance risks.



Checklists

Question	Considerations
Is the AI system **appropriate and reliable** for your entity's intended uses?	To assist with meeting your organisation's privacy obligations, particularly regarding accuracy under APP 10, consider: • Has the system been tested and proven for your entity's intended uses? • Do you understand the limitations of the product and whether there are mitigations or safeguards in place? • Is the intended use of the AI system likely to be a high privacy risk activity, such as making decisions that may have a legal or similarly significant effect on an individual's rights? • If there is a high privacy risk, will the product be appropriate and produce accurate outputs? Will your organisation be able to understand and explain these outputs and how the system works?
Can you **clearly identify the data** that the system has been trained on, to ensure that its output will be accurate?	To help assess whether your use of the AI system will be compliant with your APP 10 obligations: • Do you understand where and how the system has been trained? • Are the training datasets appropriate and relevant to your entity's purposes and functions? • Has your organisation carried out testing to identify the risk of inaccurate responses?

Question	Considerations
What are the **potential security risks** associated with the system?	It is important to consider your entity's security obligations under APP 11 when selecting an AI product. Consider: • Can you find information about any past security incidents for the system? • What security measures have been put in place by the developer to detect and protect against threats and attacks?
What is the **intended operating environment** for the AI system?	As part of assessing your APP 11 obligations, consider: • Will the AI system will be integrated into your entity's systems and have access to its documents? • Will the product be hosted through the cloud? If so, what are the privacy and security risks in relation to this?
Will your **inputs be accessible** by the system developer?	Your use of the AI system must be compliant with your APP 6 obligations regarding the disclosure of personal information. Ensure you understand: • Do the system's terms of use allow the developer access to personal information input into, or generated by, the system? • If so, can your organisation opt-out or place controls around the use of the system?

Checklist 1 – privacy considerations when selecting an AI product

Question	Considerations
Are you **using or disclosing personal information** in the context of an AI system?	To assess whether you will be compliant with your entity's obligations under APP 6, consider: • Is the purpose for which you intend to use or disclose the personal information the same as the purpose for which you originally collected it? • If it is a secondary use or disclosure, would the individual reasonably expect you to use or disclose it for the secondary purpose? • If it is a secondary use or disclosure, is it related to the primary purpose of collection (or if the information is sensitive information, is it directly related to the primary purpose?)
Are you **collecting, generating or inferring personal information** using an AI system?	To assess whether you will be compliant with your entity's obligations under APP 3, consider: • Is the collection or generation reasonably necessary for your entity's functions or activities? • Are you collecting or generating personal information using AI only by lawful and fair means? • Would it be unreasonable or impracticable to collect the personal information directly from the individual? • If you're collecting or generating sensitive information using AI, do you have the individual's consent?

Question	Considerations
Have you taken **reasonable steps to ensure the accuracy** of personal information in relation to the AI system?	To comply with your APP 10 obligations, your business should consider: • Is the personal information being input into the product accurate and of a high quality? • Do your records clearly indicate where information is the product of an AI output and therefore a probabilistic assessment rather than fact? • Do you have processes in place to ensure appropriate human oversight of AI outputs, with a human user responsible for verifying the accuracy of any personal information obtained through AI? • Does your organisation ensure that individuals are made aware of when AI is used in ways that may materially affect them?
Has your organisation **put in place appropriate transparency and accountability** measures?	To comply with your business's obligations under APP 1 and APP 5, you should consider: • Have you informed individuals about how their personal information is used in connection with AI, including at the time you collect their information and in your organisation's Privacy Policy? • Does your organisation have in place procedures and resources to be able to understand and explain the AI systems you are using, and particularly how they use, disclose and generate personal information?

Question	Considerations
What **ongoing assurance processes** need to be put in place?	Your organisation will need to ensure it has established appropriate processes and systems to ensure it complies with its APP obligations throughout the lifecycle of the AI system. Consider: • Do you have policies in place that outline the permitted and prohibited uses of the system? • Have you provided appropriate training of staff about the operation of the AI system and the potential privacy and security risks? • Do you have processes in place to provide ongoing monitoring of AI systems to ensure they are operating as intended? Have you provided for regular audits or reviews?

Checklist 2 – privacy considerations when using an AI product

Downloads

Updated: 21 October 2024

[1] Department of Industry, Science and Resources (DISR), *Proposals paper for introducing mandatory guardrails for AI in high-risk settings* - external site, DISR, September 2024, p. 32.

[2] Generative AI in particular raises a number of other issues which are in the remit of other Australian regulators, such as online safety and consumer protection. For further information see: Digital Platform Regulators Forum (DP-REG), *Working Paper 2: Examination of technology – Large Language Models* - external site, DP-REG, 25 October 2023 and DP-REG, *Working Paper 3: Examination of technology –Multimodal Foundation Models* - external site, DP-REG, 19 September 2024.

[4] Australian Signal Directorate's Australian Cyber Security Centre (ACSC), 'An introduction to Artificial Intelligence - external site', ACSC, November 2023, accessed 2 September 2024; Business.gov.au, 'Artificial intelligence (AI) - external site', July 2024, accessed 2 September 2024.

[5] Productivity Commission, *Making the most of the AI opportunity: AI update, productivity and the role of government* - external site, Research paper 1, Productivity Commission, 2024, accessed 2 September 2024, p. 2.

[6] Organisation for Economic Co-operation and Development (OECD), *What is AI? Can you make a clear distinction between AI and non-AI systems?* - external site, OECD AI Policy Observatory website, 2024.

[8] For further information on how some artificial intelligence terms interrelate see the technical diagram in F Yang et al, *GenAI concepts* - external site, *ADM+S* and *OVIC*, 2024.

[10] DISR, *Proposals paper for introducing mandatory guardrails for AI in high-risk settings* - external site, DISR, September 2024, p. 55. Unlike general-purpose AI models, narrow AI systems cannot be used for a broader range of purposes without being re-designed.

[11] DISR proposals paper – p 26.

[18] An hallucination occurs where an AI model makes up facts to fit a prompt's intent – this occurs when an AI system searches for statistically appropriate words in processing a prompt, rather than searching for the most accurate answer: F Yang et al, *GenAI concepts* - external site, *ADM+S* and *OVIC*, 2024. A deepfake is a digital photo, video or sound file of a real person that has been edited to create a realistic or false depiction of them saying or doing something they did not actually do or say: eSafety Commissioner (eSafety), *Deepfake trends and challenges — position statement* - external site, eSafety, 19 August 2024.

[19] UK ICO, 'What about fairness, bias and discrimination?' - external site, *Guidance on AI and data protection,* UK ICO, accessed 7 August 2024; OECD, 'AI, data governance, and privacy: Synergies and areas of international co-operation', pp 21-22.

[20] Note that although AI poses significant issues in relation to explainability, these are not covered more broadly in this guidance which focuses on the privacy risks of AI.

[21] OECD, 'AI, Data Governance and Privacy: Synergies and areas of international co-operation - external site', *OECD Artificial Intelligence Papers*, No. 22, OECD, June 2024, accessed 2 September 2024, p. 21. For more on de-identification see OAIC, *De-identification and the Privacy Act*, OAIC, 21 March 2018.

[22] Bell, G., Burgess, J., Thomas, J., and Sadiq, S, *Rapid Response Information Report: Generative AI - language models (LLMs) and multimodal foundation models (MFMs)* - external site, 24 March 2023; National Cyber Security Centre (UK), *ChatGPT and large language models: what's the risk?* - external site, 14 March 2023.

[24] Organisation for Economic Development (OECD), 'AI, Data Governance and Privacy: Synergies and areas of international co-operation - external site', *OECD Artificial Intelligence Papers*, No. 22, OECD, June 2024, accessed 2 September 2024; DP-REG, *Working Paper 3: Examination of technology – Multimodal Foundation Models* - external site, DP-REG, 19 September 2024, p. 24; UK Information Commissioner's Office (UK

ICO), *Generative AI first call for evidence: The lawful basis for web scraping to train generative AI models | ICO* - external site, UK ICO, 2024, accessed 2 September 2024.

[25] A number of these issues are directly relevant to other areas of law. For considerations from some other regimes, see National Artificial Intelligence Centre, *Voluntary AI Safety Standard* - external site, DISR, August 2024, pp 11-12; DP-REG, *Working Paper 3: Examination of technology – Multimodal Foundation Models* - external site, DP-REG, August 2024; DP-REG, *Working Paper 2: Examination of technology – Large Language Models* - external site, DP-REG, 25 October 2023.

[26] The eSafety Commissioner (eSafety) is Australia's independent regulator and educator for online safety. eSafety provides more information on the online safety risks and harms of generative AI. eSafety Commissioner (eSafety), *Deepfake trends and challenges — position statement* - external site, eSafety, 19 August 2024.

[27] Data poisoning involves manipulating an AI model's training data so that the model learns incorrect patterns and may misclassify data or produce inaccurate, biased or malicious outputs: Australian Signals Directorate's Australian Cyber Security Centre (ACSC), *Engaging with Artificial Intelligence (AI)* - external site, ACSC, accessed 2 September 2024, p. 6.

[29] I Shumailov et al, 'AI models collapse when trained on recursively generated data', *Nature*.

[30] Bridget McArthur, 'AI chatbot blamed for psychosocial workplace training gaffe at Bunbury prison - external site', ABC News, updated 21 August 2024, accessed 2 September 2024.

[33] Thomas Davenport and Ravi Kalakota, 'The potential for artificial intelligence in healthcare - external site', *Future Healthcare Journal,* 2019, 6(2), accessed September 2024.

[35] Federal Office for Information Security (France), *AI Coding Assistants* - external site, September 2024, pp. 9-11.

[36] Confederation of European Data Protection Organisations (CEDPO), *Generative AI: The data protection implications* - external site, CEDPO October 2023, accessed 2 September 2024, p. 6.

[40] APP 3.3 requires entities to obtain consent before collecting sensitive information unless an exception under APP 3.4 applies. For more information, see 'Chapter 3: APP 3 Collection of solicited personal information', *APP Guidelines*, OAIC, 22 July 2019.

[46] Entities should also consider and comply with other obligations and laws that apply to the use of recording devices such as State and Territory surveillance device laws: Existing

surveillance device laws | ALRC - external site.

[47] See APP 3.6.

[51] See discussion of capability in Y Benigo et al, 'International Scientific Report on the Safety of Advanced AI: Interim Report - external site', DIST research paper series, number 2023/009, 2024 pp21-22, 26-27.

[53] For example, see: Sarah Ayoub, 'Recruitment by robot: how AI is changing the way Australians get jobs - external site', The Guardian (Australia), 23 October 2023, accessed 2 September 2024.

[54] For example, 'human in the loop' processes enable humans to make decisions, provide approvals, or correct and prevent potential errors, while 'human in command' ensures that humans have ultimate control over the AI system and make the important decision: F Yang et al, *GenAI concepts* - external site, *ADM+S* and *OVIC*, 2024.

[55] OECD, 'AI, Data Governance and Privacy: Synergies and areas of international co-operation - external site', *OECD Artificial Intelligence Papers*, No. 22, OECD, June 2024, accessed 2 September 2024, p. 36; Office of the Victorian Information Commissioner (OVIC), *Artificial Intelligence and Privacy – Issues and Challenges* - external site, OVIC, accessed 2 September 2024.

Did you find this helpful?

Yes

No